

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

Course	GRC102 – Information Security Governance
Module	Module 3 – Roles and Responsibilities in Security Governance
Week	Week 3: 19–25 September 2026
Opens	19 September 2026, 8:00 AM WAT
Due	25 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	10% – Practical Laboratories

Submission mode: Written report + supporting evidence

Scenario-based governance laboratory • No production-system access is required

1. Laboratory Overview

TechGlobal is a fast-growing technology organisation with approximately 2,500 employees across five global offices. Revenue and product adoption are increasing, but its security governance model has not matured at the same pace. Most security decisions are still concentrated with the IT Director, there is no formal governance committee structure, business units operate inconsistently, and the CEO and Board receive limited visibility into cyber risk.

You have been appointed Lead Security Governance Consultant. Your task is to redesign TechGlobal's governance model so that security decisions are business-aligned, accountabilities are clear, conflicts are resolved appropriately, and material cyber risks can be escalated from operational teams to executive management and the Board.

2. Learning Objectives

- Analyse weaknesses created by informal, IT-centric security governance.
- Design a scalable governance structure linking Board oversight, executive leadership, security management and business units.
- Define clear responsibilities and decision authority for the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR and IT.
- Design an effective cross-functional Security Governance Committee structure.
- Apply a RACI model to eliminate ambiguity and improve accountability.
- Design a material cyber-risk escalation workflow and decision trail.
- Identify segregation-of-duties conflicts and recommend practical corrective controls.

3. Scenario and Stakeholder Context

TechGlobal's current model can be described as "security by informal decision." The IT Director is effectively acting as security owner, risk approver and operational decision-maker. Business-unit leaders make local security choices, and there are no formal committees or reliable escalation paths. This creates concentration of authority, inconsistent control ownership, weak oversight and limited Board visibility.

Stakeholder	Governance Role	Primary Concerns
Board of Directors	Oversight and risk appetite	Regulatory exposure, brand reputation, material risk, assurance and accountability.
CEO	Executive accountability	Growth, strategic alignment, acceptable risk and business performance.
CISO	Security governance leadership	Security strategy, policy, risk oversight, reporting and programme effectiveness.
CRO / Risk	Enterprise risk integration	Risk methodology, risk acceptance, treatment and enterprise aggregation.
Legal / Compliance	Legal and regulatory advice	Regulatory duties, contractual obligations, privacy, evidence and notification.
Finance	Financial governance	Budget, loss exposure, investment prioritisation and financial controls.
Human Resources	People governance	Joiner/mover/leaver controls, awareness, conduct and disciplinary processes.
IT / Technology	Technology delivery	Secure operation, implementation, technical control ownership and service continuity.
Business Unit Leaders	Business ownership	Operational performance, local risk decisions and control implementation.

4. Task 1 Governance Architecture and Stakeholder Map (20 marks)

The Board has asked you to replace the current informal model with a governance structure that connects operational security decisions to executive and Board oversight.

Governance Gap Assessment

TechGlobal has several security governance weaknesses that affect decision-making, accountability and risk management across its 2,500 employees and five offices.

Key Governance Gaps

1. Centralised decision-making: Security decisions are concentrated with the IT Director.
2. No formal governance committee: There is limited cross-departmental coordination.
3. Inconsistent security practices: Business units make different security decisions.
4. Limited executive visibility: The CEO and Board do not receive sufficient security information.
5. Weak escalation procedures: There are no reliable paths for escalating security risks.
6. Lack of segregation of duties: The IT Director manages security ownership, risk approval, and operational decisions.

Recommended Improvements

TechGlobal should:

- Establish a Security Governance Committee.
- Define clear security responsibilities across departments.
- Create documented risk escalation procedures.
- Separate security leadership, risk approval, and technical implementation.
- Improve reporting to the CEO and Board.
- Make cybersecurity an organisation-wide responsibility, not just an IT function.

Conclusion

The proposed governance improvements will strengthen accountability, improve risk oversight, support consistent security practices, and enhance cybersecurity resilience across all five offices.

Identified Governance Gaps

No.	Governance Weakness	Business or Risk Consequence
1	Security decisions are concentrated with the IT Director.	Creates excessive dependence on one person and increases the risk of insufficient independent review.
2	There is no formal Security Governance Committee.	Security, risk, finance, legal, and business priorities may not be coordinated effectively.
3	Business units make inconsistent security decisions.	Creates uneven security controls across the five global offices.
4	The CEO and Board have limited visibility into cyber risk.	Senior leadership may not understand major cyber threats, financial exposure, or decisions requiring oversight.
5	There are no reliable escalation paths.	Significant cyber incidents may not reach executive management or the Board quickly enough.
6	The IT Director acts as security owner, risk approver, and operational decision-maker.	Creates a segregation-of-duties concern because one person controls several stages of the decision process.

Evidence of Stakeholder Mapping

The stakeholder map identifies the key stakeholders involved in TechGlobal's security governance. It documents their interests, authority, information needs, and expected contributions.

Stakeholder Analysis

Stakeholder	Interests	Authority	Information Needs	Expected Contribution
Board of Directors	Business resilience, compliance, reputation, and strategic risk	Provides oversight and approves major strategic decisions	Major risks, incidents, compliance, and security performance	Provides oversight and accountability
CEO	Business continuity, performance, and risk management	Approves strategic priorities and provides executive direction	Critical risks, incidents, financial impact, and security performance	Provides executive sponsorship
CISO	Security strategy, risk reduction, and incident response	Leads security governance and recommends security decisions	Security risks, incidents, controls, and audit findings	Develops security strategy and coordinates security activities
		Coordinates risk		Integrates

Evidence Reference: https://github.com/rebeccakalende/GRC102_Week3_Lab/blob/main/README.md#12-stakeholder-map

1.3 Security Governance Organisation Chart

The proposed security governance organisation chart establishes clear reporting relationships between the Board of Directors, CEO, Security Governance Committee, CISO, Risk Management, and operational departments.

The Board provides strategic oversight, while the CEO provides executive leadership. The Security Governance Committee supports cross-functional coordination, and the CISO leads cybersecurity strategy and governance activities.

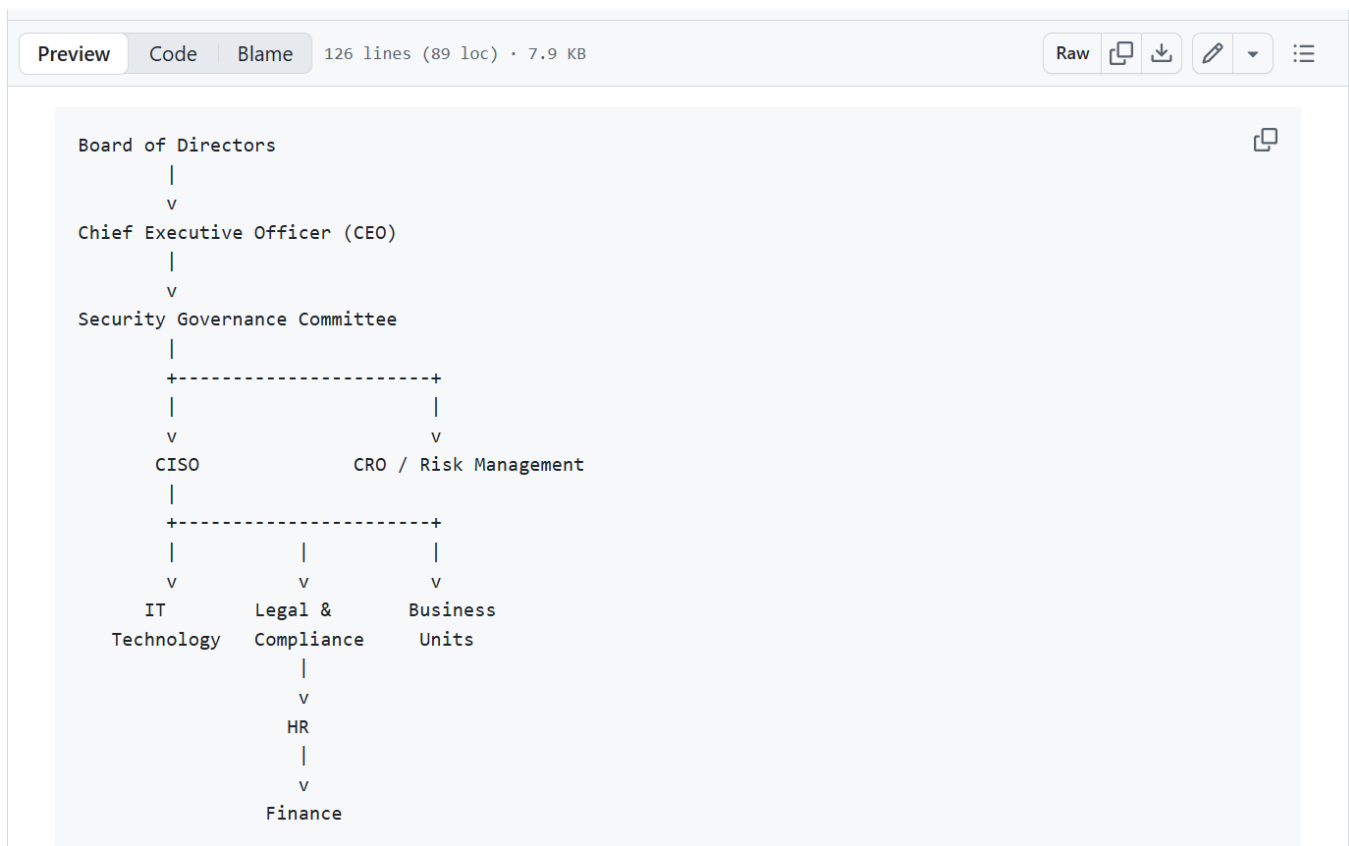
Risk Management provides independent risk oversight, while IT, Legal and Compliance, HR, Finance, and business units support the implementation of security requirements within their respective areas.

Suitability for TechGlobal

The proposed structure is suitable for TechGlobal because the organisation has approximately 2,500 employees across five offices. It supports consistent security governance by distributing responsibilities across executive leadership, technical teams, risk management, and business departments.

The structure also reduces the concentration of authority within the IT Director role. Separating security leadership, risk oversight, and technical implementation supports accountability, independent review, and improved escalation of significant security risks.

Proposed Security Governance Structure



5. Task 2 Governance Responsibility and Authority Matrix (20 marks)

2.1 Responsibility and Authority Matrix

The responsibility and authority matrix defines the responsibilities of key stakeholders in TechGlobal's security governance structure. It clarifies who leads, approves, advises, and implements security-related activities.

The matrix is designed to reduce confusion, prevent excessive concentration of authority, and improve accountability across the organisation.

Role	Main Responsibilities	Decision-Making Authority	Accountability
Board of Directors	Strategic oversight and governance supervision	Approves major strategic risk decisions	Overall governance oversight
CEO	Executive leadership and business alignment	Approves strategic priorities and major business decisions	Executive accountability
Security Governance Committee	Coordinates security governance and reviews key risks	Recommends and coordinates governance decisions	Cross-functional governance coordination
CISO	Security strategy, policies, and security performance	Recommends security decisions and leads security governance	Security programme accountability
CRO / Risk Management	Risk assessment, risk treatment, and risk reporting	Challenges and reviews risk decisions	Enterprise risk oversight
Legal / Compliance	Legal, regulatory, privacy, and compliance guidance	Advises on compliance and regulatory obligations	Legal and compliance accountability
Finance	Security budgeting and financial oversight	Reviews or approves spending according to policy	Financial accountability
HR	Security awareness, training, and employee conduct	Manages employee-related processes	Workforce security accountability
IT / Technology	Technical controls, infrastructure security, and operations	Implements approved technical changes and controls	Technical implementation accountability
Business Unit Leaders	Business-level security responsibilities and operational compliance	Makes decisions within assigned business authority	Business unit accountability

- Develop a responsibility profile for the Board, CEO, CISO, Legal, Finance, HR and IT.CRO/Risk,
- For each role, define purpose, key governance responsibilities, decision authority, reporting obligations and at least two performance indicators.
- Identify at least three areas where authority could overlap or conflict and explain how the governance model should resolve those conflicts.

Required Evidence Task 2

- Cross-functional Governance Responsibility Matrix.
- Role profiles / responsibility cards for the eight core governance roles.
- Short conflict-resolution note identifying overlapping authority and resolution principles.

6. Task 3 Security Governance Committee Ecosystem (20 marks)

6.1 Governance Structure

TechGlobal will establish a multi-level security governance structure to ensure that security risks, investments, compliance, and technology decisions are reviewed collectively.

The structure will include:

1. **Executive Security Council:** Provides strategic oversight and approves major security decisions.
2. **Security Governance Steering Committee:** Coordinates cross-functional security governance and risk management.
3. **Incident Response and Cybersecurity Working Group:** Handles operational security incidents and recommends improvements.
4. **Business Unit Security Representatives:** Support implementation and communication without creating separate security silos.

6.2 Committee Responsibilities

Executive Security Council

The council will include the CEO, CISO, CRO/Risk Manager, Finance, Legal and Compliance, and business representatives.

Its responsibilities include:

- Reviewing strategic security priorities and major investments.
- Monitoring significant security risks and incidents.
- Approving major risk treatment decisions.
- Escalating material risks to the Board.

The council will meet quarterly or when significant security matters arise.

Security Governance Steering Committee

The committee will be chaired by the CISO and include representatives from Risk, IT, Legal and Compliance, Finance, HR, Internal Audit, and Business Units.

Its responsibilities include:

- Reviewing security risks and control gaps.
- Monitoring compliance, audits, and security performance.
- Coordinating security policies and improvement projects.
- Reviewing exceptions and recommending major decisions to the Executive Security Council.

The committee will meet monthly.

Specialised Working Group

The Incident Response and Cybersecurity Working Group will coordinate incident detection, investigation, containment, recovery, and post-incident reviews. Significant incidents will be escalated to the Steering Committee.

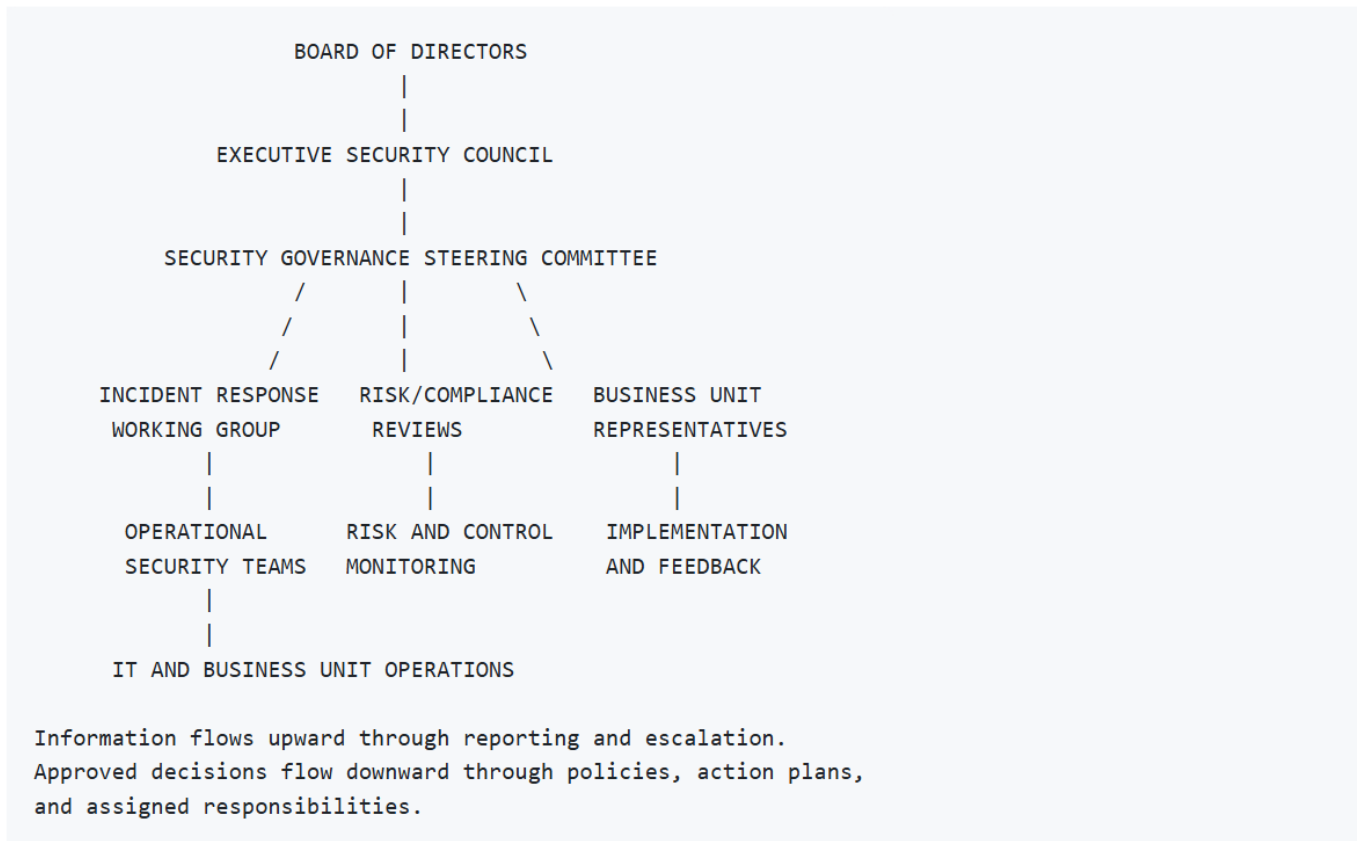
6.3 Business Unit Participation and Information Flow

Business Unit Security Representatives will communicate policies, identify risks, support awareness activities, and monitor the implementation of security actions.

Security information will flow from operational teams to the Working Group, then to the Steering Committee and Executive Security Council. Material risks, major investments, and significant organizational impacts will be escalated to the Board.

Approved decisions will flow back to operational teams through policies, action plans, and assigned responsibilities.

6.4 Committee Interaction Diagram



6.5 Terms of Reference

Purpose: Provide cross-functional oversight of security risks, controls, compliance, and improvement activities.

Chairperson: CISO.

Membership: CISO, CRO/Risk, IT, Legal and Compliance, Finance, HR, Internal Audit, and Business Unit Representatives.

Frequency: Monthly, with emergency meetings when required.

Authority: Review risks, coordinate corrective actions, recommend decisions, and escalate matters outside delegated authority.

Reporting: The committee will report security risks, incidents, audit findings, policy exceptions, and outstanding actions to the Executive Security Council.

Review: The Terms of Reference will be reviewed annually.

7. Task 4 RACI Accountability Matrix (20 marks)

7.1 Introduction

The RACI matrix defines responsibility and accountability for key security governance activities at TechGlobal. It clarifies who performs the work, who approves decisions, who must be consulted, and who should receive updates.

The matrix supports timely decision-making, reduces role confusion, and strengthens accountability during normal operations and cybersecurity incidents.

4.2 RACI Legend

Code	Meaning	Explanation
R	Responsible	Performs or coordinates the activity.
A	Accountable	Owens the final decision or outcome.
C	Consulted	Provides advice or specialist input.
I	Informed	Receives updates about the activity or decision.

7.2 TechGlobal RACI Matrix

Roles:

- **Board:** Board of Directors
- **CEO:** Chief Executive Officer
- **CISO:** Chief Information Security Officer
- **CRO:** Chief Risk Officer/Risk Manager
- **SGC:** Security Governance Committee
- **Legal:** Legal and Compliance
- **Finance:** Finance Department
- **IT:** IT/Technology
- **BU:** Business Unit Leaders

Activity	Board	CEO	CISO	CRO	SGC	Legal	Finance	
Cybersecurity strategy approval	I	A	R	C	C	C	C	
Security policy approval	I	A	R	C	C	C	I	
Enterprise cyber-risk assessment	I	I	R	A	C	C	I	
Risk acceptance	I	A	R	C	C	C	I	
Security budget approval	I	A	R	C	C	I	R	
Security architecture approval	I	A	R	C	C	C	I	
Third-party security review	I	I	A	R	C	C	I	
Access governance	I	I	A	C	C	I	I	
Incident response governance	I	A	R	C	C	C	I	
Material incident escalation	I	A	R	C	C	C	I	
Regulatory notification decision	I	A	C	C	I	R	I	
Security awareness programme	I	I	A	C	C	C	I	
Vulnerability remediation oversight	I	I	A	C	C	I	I	
Business continuity/recovery								

Note: The CEO is accountable for executive-level decisions, while the Board retains oversight of organizational cyber risk. Specific authority limits should be formally approved and documented by TechGlobal.

7.3 Problematic Assignments and Recommended Improvements

Problem 1: Risk Acceptance

The CISO is marked as Responsible while the CEO is Accountable. This arrangement may create a conflict if the CISO is both recommending a risk treatment and independently accepting the same risk.

Recommended improvement: The CRO/Risk Manager should provide independent risk review, while risk acceptance should be approved by the authorized risk owner according to defined risk thresholds.

Problem 2: Security Architecture Approval

The CISO and CEO are both marked as Accountable. Having more than one accountable role may create uncertainty about who has final approval authority.

Recommended improvement: Assign one final accountable role based on the type and impact of the architecture decision. The CISO should own security assurance, while executive approval should be required for major investments or significant risk exceptions.

Problem 3: Security Budget Approval

The CISO and Finance are both involved in budget decisions. Without clear authority limits, this may lead to delays or disagreements about spending priorities.

Recommended improvement: The CISO should be responsible for preparing the security budget and business justification. Finance should review financial controls, while the CEO or authorized executive should provide final budget approval.

7.4 RACI Implementation Guide

Managers should use the RACI matrix during planning, approvals, routine operations, and cybersecurity incidents.

Planning

At the beginning of each activity or project, the responsible manager should identify the roles listed in the matrix. The Responsible role coordinates the work, while the Accountable role confirms the expected outcome and approves decisions within their authority.

Approvals

Managers should verify that every activity has one clear Accountable role wherever practicable. Consulted stakeholders must provide input before a decision is finalized, and approval records should be retained for audit purposes.

Normal Operations

The matrix should be used when assigning tasks, reviewing security controls, planning security projects, and monitoring performance. Managers should not assign approval responsibilities to individuals who lack the required authority or independence.

Cybersecurity Incidents

During an incident, the RACI matrix should be used to identify the incident response lead, decision-maker, technical responders, and stakeholders who must be informed. Material incidents should be escalated according to the approved incident severity thresholds and escalation procedures.

Review and Maintenance

The CISO and Security Governance Committee should review the matrix at least annually or following major organizational changes, security incidents, or changes in responsibilities. Any changes must be approved, documented, and communicated to affected departments.

The RACI matrix is a governance tool and should be used together with approved policies, delegation of authority, risk thresholds, and incident response procedures.

8. Task 5 Cyber-Risk Escalation and Segregation of Duties (20 marks)

Major Cyber-Risk Escalation Workflow

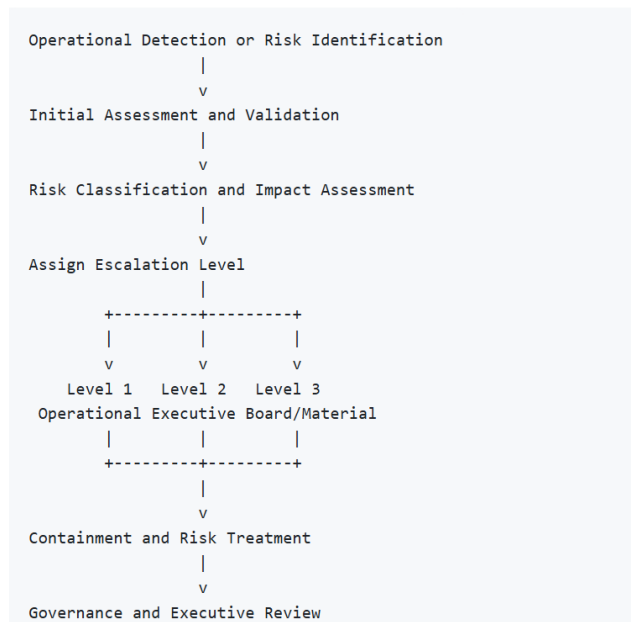
The proposed workflow begins with the detection or identification of a cyber-risk issue and ends with an authorised decision and verified closure.

Escalation Process

1. **Detection or Identification:** A cyber-risk issue is identified through security monitoring, vulnerability assessments, incident reports, audits, employee reports, or third-party assessments.
2. **Initial Assessment:** The IT or security team assesses the affected systems, potential business impact, data exposure, regulatory implications, and immediate containment requirements.
3. **Risk Classification:** The issue is classified according to severity, likelihood, business impact, and alignment with TechGlobal's risk appetite.
4. **Escalation Level Assignment:** The issue is assigned to the appropriate escalation level based on approved thresholds.
5. **Containment and Risk Treatment:** Relevant teams implement containment, remediation, recovery, additional monitoring, or other approved treatment actions.
6. **Governance Review and Decision:** The appropriate authority reviews the issue and approves the recommended response, risk acceptance, further escalation, or additional controls.
7. **Monitoring and Closure:** Actions are tracked, completion evidence is reviewed, and closure is approved by the authorised reviewer.

Workflow Diagram

Escalation Workflow



5.3 Escalation Threshold Table

Escalation Level	Trigger Criteria	Escalation Authority	Required Response
Level 1: Operational	Low-impact issue, limited systems affected, no significant business disruption, and manageable within approved procedures	IT/Security Team and relevant operational manager	Resolve the issue, document actions, and report through routine governance channels
Level 2: Executive	Significant service disruption, repeated control failure, high-risk vulnerability, cross-department impact, or need for additional resources	CISO, Security Governance Committee, and CEO	Coordinate the response, allocate resources, review treatment, and escalate further where necessary
Level 3: Board/Material Risk	Major business disruption, significant data exposure, regulatory implications, substantial financial impact, or risk exceeding organisational risk appetite	Executive Security Council, CEO, and Board	Make strategic decisions, approve risk treatment, oversee recovery, and review material risk exposure

Escalation should be based on the potential business and organisational impact of the risk rather than technical severity alone. Legal and Compliance should be consulted when regulatory, contractual, or reporting obligations may apply. Risk acceptance must be approved by an authorised risk owner.

5.4 Segregation-of-Duties and Accountability Weakness Register

An IT-centric governance model may create conflicts when one individual or department controls several stages of a security or risk decision. The following weaknesses and controls are proposed for TechGlobal.

No.	Potential Weakness	Risk Created	Recommended Control
1	One IT employee requests, approves, and implements privileged access	Unauthorised or inappropriate access may be granted without independent review	Separate access request, approval, and implementation. Conduct periodic privileged-access reviews
2	The CISO recommends and independently approves major risk acceptance	Risk decisions may lack independent challenge	Require CRO/Risk review and approval by an authorised business risk owner
3	The same person requests and approves high-risk system changes	Unauthorised or poorly assessed changes may be introduced	Require independent change approval, documented testing, and post-implementation review
4	IT controls security budgets without independent financial review	Security expenditure may lack oversight or appropriate prioritisation	Require Finance review and approval through the authorised budget process
5	IT investigates and closes significant incidents without independent oversight	Incidents may be closed prematurely or evidence may be incomplete	Require CISO, Security Governance Committee, or independent review for significant incidents
6	Business units bypass security controls to meet operational deadlines	Unmanaged exceptions may increase organisational risk	Require documented exceptions, risk assessment, authorised approval, expiry dates, and periodic review

The recommended controls should be proportionate to the level of risk. Routine, low-risk activities can follow standard procedures, while high-risk activities should require independent review and material decisions should receive executive or Board oversight.

5.5 Decision Recording and Assurance Note

TechGlobal should maintain a central Security Decision Register for significant cybersecurity, risk, and governance decisions. The register will provide evidence of the decision made, the authority used, the information considered, and the actions required.

Required Decision Register Fields

The register should include:

- Decision ID.
- Date raised and date decided.
- Description of the issue or decision.
- Risk and business impact.
- Options considered.
- Recommended action.
- Decision-maker.
- Consulted stakeholders.
- Approval authority.
- Assigned actions and deadlines.
- Action owners.
- Supporting evidence.

- Current status.
- Review date.
- Closure date and approval.

Decision Tracking and Closure

The decision-tracking process should follow these steps:

1. Record the issue or decision in the central register.
2. Assign a responsible owner.
3. Review the risk and recommendation with the appropriate authority.
4. Record the decision and supporting rationale.
5. Assign actions with clear deadlines.
6. Monitor progress through the relevant governance committee.
7. Escalate overdue or unresolved actions.
8. Verify completion evidence and approve closure.

The CISO should oversee cybersecurity decisions and ensure that significant issues are reported through the appropriate governance channels. The Security Governance Committee should review open risks, overdue actions, major incidents, risk acceptance decisions, policy exceptions, control failures, and high-risk vulnerabilities.

The CRO/Risk function should provide independent risk challenge, while Internal Audit or another independent assurance function may periodically review the register to verify that decisions were authorised, segregation-of-duties controls were followed, actions were completed, and evidence was retained.

Illustrative Decision Register

Decision ID	Decision	Decision Owner	Required Action	Status
SEC-001	Remediate a high-risk vulnerability	CISO/IT	Patch affected systems and provide evidence	Open
SEC-002	Approve a temporary security exception	Authorised Risk Owner	Apply compensating controls and review expiry date	Under Review
SEC-003	Escalate a material cyber-risk issue	CEO/Executive Security Council	Review business impact and determine further action	Open

The entries above are illustrative examples. Actual organisational decisions should be recorded in the approved decision register with supporting evidence.

5.6 Expected Outcomes

The proposed framework is expected to:

- Improve the consistency of cyber-risk escalation.
- Clarify operational, executive, and Board-level decision-making authority.
- Reduce conflicts of interest within the IT-centric model.
- Strengthen independent risk oversight.
- Improve accountability for risk treatment and closure.
- Provide an auditable record of significant security decisions.
- Support informed executive and Board-level risk management.
- Reduce undocumented risk acceptance and delayed escalation.

5.7 Task 5 Conclusion

The proposed cyber-risk escalation and segregation-of-duties framework provides TechGlobal with a structured approach to managing cybersecurity risks. Clear escalation thresholds ensure that risks reach the appropriate authority, while segregation-of-duties controls reduce conflicts and strengthen independent oversight.

The central decision register supports transparency, accountability, and auditability by ensuring that significant decisions, assigned actions, supporting evidence, and closure approvals are documented and reviewed.